Segurança em Redes de Computadores

Heron Aragão Monteiro

Segurança em Redes de Computadores

Livro texto

Redes de Computadores e a Internet
(Uma abordagem top-down)

James F. Kurose e Keith W. Ross
6ª edição
Pearson Education do Brasil
2013

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Introdução
  - Dada a natureza hostil da Internet, é considerada a rede de uma organização e o seu administrador
  - Do ponto de vista de um administrador, o mundo se divide em dois campos
    - Os mocinhos
      - Que pertencem à rede da organização e que deveriam ser capazes de acessar recursos dentro da rede da organização de maneira relativamente irrestrita
    - Os bandidos
      - As demais pessoas, cujo acesso aos recursos da rede deve ser cuidadosamente examinado

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

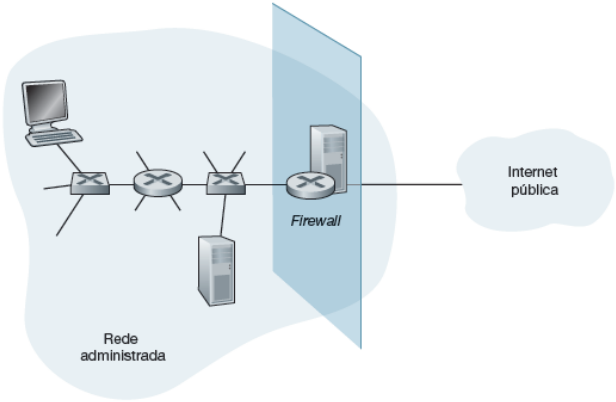
- Introdução
  - Em muitas organizações existe um único ponto de entrada/saída onde todos que entram e saem da organização são verificados em termos de segurança
  - Em uma rede de computadores, o tráfego que entra/sai de uma rede é verificado, registrado, descartado ou encaminhado por dispositivos operacionais conhecidos como firewalls, sistemas de detecção de intrusões (IDSs) e sistemas de prevenção de intrusões (IPSs)

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Um firewall é uma combinação de hardware e software
  - Ele isola a rede interna de uma organização da Internet em geral
  - Permite a passagem de alguns pacotes e bloqueia outros
  - Permite que um administrador de rede controle o acesso entre o mundo externo e os recursos dentro da rede
    - Através do gerenciamento do fluxo de tráfego de e para esses recursos

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Um firewall tem três metas
    - Todo o tráfego de fora para dentro e vice-versa passa pelo firewall
      - Embora as grandes organizações possam usar vários níveis de firewalls ou firewalls distribuídos, localizar um firewall em um único ponto de acesso à rede facilita o gerenciamento e a aplicação de uma política de acesso de segurança



Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Um firewall tem três metas
    - Somente o tráfego autorizado, conforme definido pela política de segurança local, poderá passar
    - O próprio firewall deve ser imune à invasão
      - O firewall é um dispositivo conectado à rede
      - Se não for projetado ou instalado corretamente, ele poderá ser comprometido
        - Fornecendo uma falsa sensação de segurança, o que é pior do que nenhum firewall.

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Cisco e Check Point são dois dos principais fornecedores de firewall
  - Um firewall pode ser criado facilmente a partir de uma máquina Linux usando iptables
    - Software de domínio público que normalmente é fornecido com o Linux
  - Os firewalls são frequentemente implementados em roteadores e controlados remotamente por meio de SDNs (software-defined networks)

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Categorias
    - Filtros de pacotes tradicionais
    - Filtros de estado
    - Gateways de aplicação

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Uma organização normalmente possui um roteador gateway conectando sua rede interna ao seu ISP
    - Todo o tráfego que sai e entra na rede interna passa por este roteador
    - É nele que ocorre a filtragem de pacotes
      - Cada datagrama é examinado isoladamente, determinando se o datagrama deve passar ou ser descartado com base em regras específicas do administrador

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - As decisões de filtragem são normalmente baseadas em
      - Endereço IP de origem ou destino
      - Tipo de protocolo no campo do datagrama IP
        - TCP, UDP, ICMP, OSPF, ...
      - Porta de origem e destino TCP ou UDP
      - Bits de sinalização TCP: SYN, ACK e assim por diante
      - Tipo de mensagem ICMP
      - Regras diferentes para datagramas saindo e entrando na rede
      - Regras diferentes para as diferentes interfaces do roteador

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Um administrador de rede configura o firewall com base na política da organização
    - A política pode levar em consideração
      - A produtividade do usuário e o uso da largura de banda
      - As preocupações de segurança de uma organização

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Políticas e regras de filtragem correspondentes para a rede 130.207/16 de uma organização com servidor web 130.270.244.203

Política	Configuração de *firewall*
Não há acesso exterior à Web	Descartar todos os pacotes de saída para qualquer endereço IP, porta 80
Não há conexões TCP de entrada, exceto aquelas apenas para o servidor Web público da organização	Descartar todos os pacotes TCP SYN para qualquer IP exceto 130.207.244.203, porta 80
Impedir que rádios Web devorem a largura de banda disponível	Descartar todos os pacotes UDP de entrada — exceto pacotes DNS
Impedir que sua rede seja usada por um ataque DoS	Descartar todos os pacotes *ping* que estão indo para um endereço de difusão (por exemplo, 130.207.255.255)
Impedir que a rota de sua rede seja rastreada	Descartar todo o tráfego de saída ICMP com TTL expirado

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Regras dos firewalls são implementadas em roteadores com listas de controle de acesso
      - Cada interface do roteador contém a sua própria lista

Ação	Endereço de origem	Endereço de destino	Protocolo	Porta de origem	Porta de destino	Bit de flag
Permitir	222.22/16	Fora de 222.22/16	TCP	> 1023	80	Qualquer um
Permitir	Fora de 222.22/16	222.22/16	TCP	80	> 1023	ACK
Permitir	222.22/16	Fora de 222.22/16	UDP	> 1023	53	—
Permitir	Fora de 222.22/16	222.22/16	UDP	53	> 1023	—
Negar	Todos	Todos	Todos	Todos	Todos	Todos

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Regras dos firewalls são implementadas em roteadores com listas de controle de acesso
      - Essa lista é para uma interface que conecta o roteador aos ISPs externos da organização
      - As regras são aplicadas a cada datagrama que atravessa a interface de cima para baixo
      - As primeiras duas regras juntas permitem que usuários internos naveguem na Web
        - A a primeira permite que qualquer pacote TCP com porta de destino 80 saia da rede da organização
        - A segunda autoriza que qualquer pacote TCP com porta de origem 80 e o bit ACK marcado entre na rede

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacotes tradicionais
    - Regras dos firewalls são implementadas em roteadores com listas de controle de acesso
      - As próximas duas regras juntas permitem que pacotes DNS entrem e saiam da rede da organização
      - Em resumo, essa lista bloqueia todo o tráfego exceto
        - O tráfego Web iniciado de dentro da organização
        - O tráfego DNS

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Os filtros de estado rastreiam conexões TCP e usam esse conhecimento para tomar decisões sobre filtragem
    - A lista anterior permite que qualquer pacote que chegue de fora com um ACK=1 e porta de origem 80 atravesse o filtro
      - Esses pacotes poderiam ser usados em tentativas de destruir o sistema interno com pacotes defeituosos, realizar ataques de recusa de serviço, ou mapear a rede interna
      - Uma primeira solução seria bloquear pacotes TCP ACK também
        - Mas impediria que os usuários internos da organização navegassem na Web

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Os filtros de estado resolvem esse problema
      - Rastreando todas as conexões TCP de entrada em uma tabela de conexão
    - O firewall pode notar o início de uma nova conexão observando uma apresentação de três vias (SYN, SYNACK e ACK)
    - Ele também pode observar o fim de uma conexão ao ver um pacote FIN para a conexão
      - Ou admitir que a conexão está finalizada quando ao não observar nenhuma atividade no decorrer da conexão
        - Por exemplo, por 60 segundos

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Exemplo de tabela de conexão

Endereço de origem	Endereço de destino	Porta de origem	Porta de destino
222.22.1.7	37.96.87.123	12699	80
222.22.93.2	199.1.205.23	37654	80
222.22.65.143	203.77.240.43	48712	80

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Lista de controle de acesso para filtros de estado

Ação	Endereço de origem	Endereço de destino	Protocolo	Porta de origem	Porta de destino	Bit de flag	Verificar conexão
Permitir	222.22/16	Fora de 222.22/16	TCP	>1023	80	Qualquer um	
Permitir	Fora de 222.22/16	222.22/16	TCP	80	>1023	ACK	X
Permitir	222.22/16	Fora de 222.22/16	UDP	>1023	53	—	
Permitir	Fora de 222.22/16	222.22/16	UDP	53	>1023	—	X
Negar	Todos	Todos	Todos	Todos	Todos	Todos	

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Exemplo 1
      - Supondo que um atacante tente enviar um pacote defeituoso para a rede da organização por um datagrama com porta de origem TCP 80 e com o flag ACK marcado (sem a troca de mensagens com as flags SYN e SYNACK)
        - Supondo também que ele possua um número de porta de origem 12543 e endereço IP remetente 150.23.23.155
        - Quando o pacote chega ao firewall vai ser verificada a lista de controle de acesso
          - Que indica que a tabela de conexão deve também ser verificada antes de permitir que esse pacote entre na rede da organização
        - O firewall verifica a tabela de conexão e observa que esse pacote não faz parte de uma conexão TCP em andamento, e o rejeita

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Filtros de pacote com controle de estado
    - Exemplo 2
      - Caso um usuário interno queira navegar em um site externo ele enviará primeiro segmento TCP SYN
      - Sua conexão TCP é registrada na tabela de conexão
      - Quando o servidor envia pacotes de volta (com o bit ACK), o firewall verifica a tabela e observa que uma conexão correspondente está em andamento
      - O firewall deixará esses pacotes passarem, sem interferir na navegação do usuário interno

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Gateway de aplicação
    - Gateways de aplicação fazem mais do que examinar cabeçalhos IP/TCP/UDP
    - Eles tomam decisões com base em dados da aplicação
    - Um gateway de aplicação é um servidor específico de aplicação
      - Todos os dados da aplicação que entram e que saem devem passar por ele
    - Vários gateways de aplicação podem executar no mesmo hospedeiro
      - Mas cada gateway é um servidor separado, com seus próprios processos

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Gateway de aplicação
    - Exemplo
      - Está sendo projetado um firewall que permite a apenas um conjunto restrito de usuários executar a aplicação Telnet para o exterior e impede que todos os clientes externos executem Telnet para o interior
      - Essa política pode ser aplicada pela execução da combinação de um filtro de pacotes (em um roteador) com um gateway de aplicação de Telnet
      - O filtro do roteador está configurado para bloquear todas as conexões Telnet, exceto as que se originam do endereço IP do gateway de aplicação
        - Essa configuração de filtro força todas as conexões Telnet de saída a passarem pelo gateway de aplicação

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

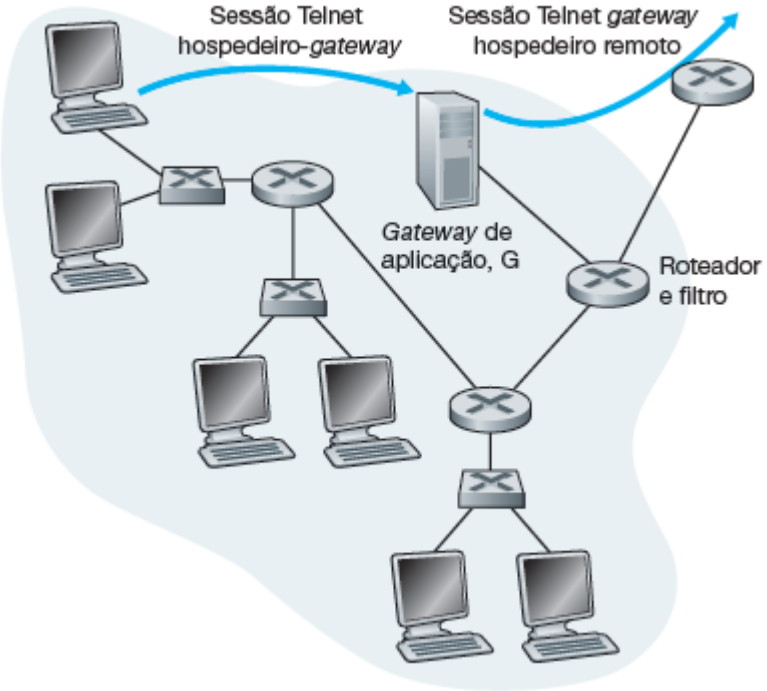
- Firewalls
  - Gateway de aplicação
    - Exemplo
      - Considerando que um usuário interno queira executar Telnet com o mundo exterior
      - Primeiro, ele tem de estabelecer uma sessão Telnet com o gateway de aplicação
      - Uma aplicação que está executando no gateway — e que fica à escuta de sessões Telnet que entram — solicita ao usuário sua identificação e senha
      - O gateway de aplicação verifica se ele tem permissão para executar Telnet com o mundo exterior
        - Se não tiver, a conexão Telnet do usuário interno ao gateway será encerrada pelo gateway
        - Se tiver, o gateway
          - Pedirá ao usuário o nome do computador externo com o qual ele quer se conectar
          - Estabelecerá uma sessão Telnet com o hospedeiro externo
          - Repassará ao hospedeiro externo todos os dados que chegam do usuário e ao usuário todos os dados que chegam do hospedeiro externo

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Gateway de aplicação
    - Exemplo
      - Assim, o gateway de aplicação Telnet não só autoriza o usuário, mas também atua como um servidor Telnet e um cliente Telnet
        - Repassando informações entre o usuário e o servidor Telnet remoto
      - O filtro permitirá a etapa 2, porque é o gateway que inicia a conexão Telnet com o mundo exterior

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Gateway de aplicação
    - Exemplo



Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Firewalls
  - Gateway de aplicação
    - Redes internas frequentemente têm vários gateways de aplicação
      - Como gateways para Telnet, HTTP, FTP e e-mail
    - Desvantagens dos gateways de aplicação
      - É preciso um gateway de aplicação diferente para cada aplicação
      - O desempenho é prejudicado porque todos os dados serão repassados por meio do gateway
      - O software cliente deve saber
        - Como entrar em contato com o gateway quando o usuário fizer uma solicitação
        - Como dizer ao gateway de aplicação a qual servidor se conectar

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Para detectar muitos tipos de ataque é preciso executar uma inspeção profunda de pacote
    - precisando olhar através dos campos de cabeçalho e dentro dos dados da aplicação que o pacote carrega
  - Gateways de aplicação frequentemente fazem inspeções profundas de pacote
    - Mas só o fazem para uma aplicação específica

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - São dispositivos que geram alertas quando observam tráfegos potencialmente mal-intencionados
  - Eles examinam os cabeçalhos de todos os pacotes ao passar por eles, como um filtro de pacotes
  - Também executam uma inspeção profunda de pacote, diferente do filtro de pacotes
  - Eles observam o pacote suspeito, ou uma série de pacotes suspeitos, impedindo que tais pacotes entrem na rede organizacional

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Quando a atividade só é vista como suspeita, o dispositivo pode deixar os pacotes passarem
    - Mas envia um alerta ao administrador de rede, que pode examinar o tráfego minuciosamente e tomar as ações necessárias
  - O Sistema de Detecção de Intrusão (IDS) é o sistema que gera alertas
  - O Sistema de Prevenção de Intrusão (IPS) é o sistema que filtra o tráfego suspeito
    - Ambos são genericamente de IDS

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

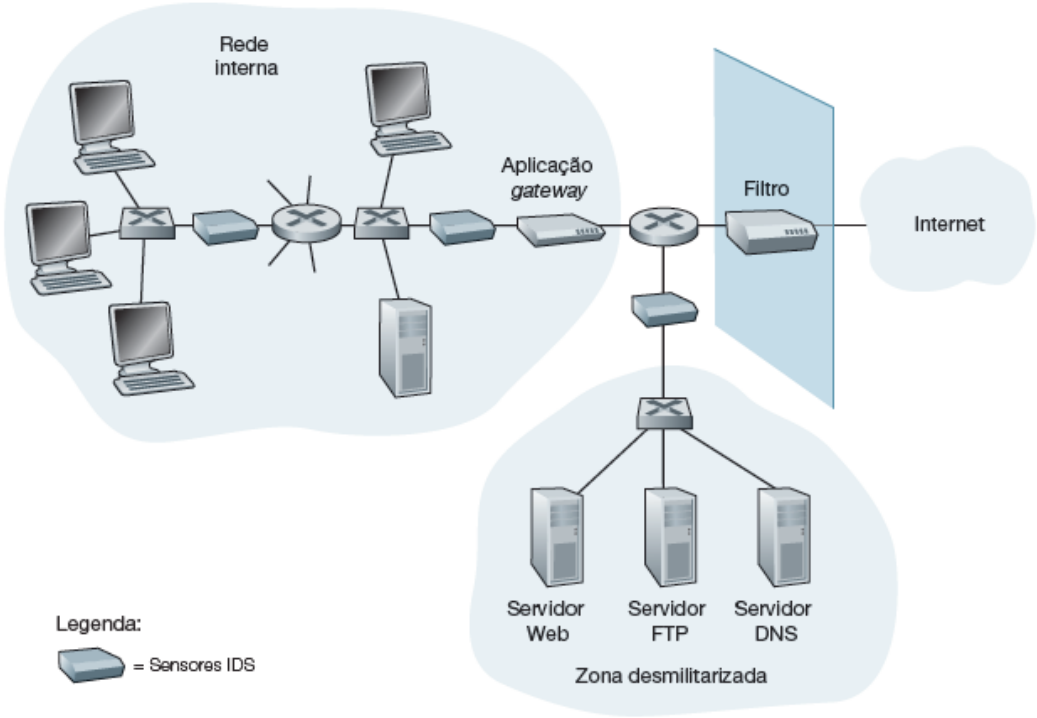
- Sistemas de detecção de invasão
  - Um IDS pode ser usado para detectar uma série de tipos de ataques
    - Como mapeamento de rede, varreduras de porta, varreduras de pilha TCP, ataques de DoS, ataques de inundação de largura de banda, worms e vírus, ataques de vulnerabilidade de OS e ataques de vulnerabilidade de aplicações
  - Milhares de organizações empregam sistemas de IDS
    - Muitos desses sistemas são patenteados, comercializados pela Cisco, Check Point, dentre outros
  - Mas há muitos sistemas de domínio público

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Uma organização pode implementar um ou mais sensores IDS em sua rede organizacional
    - Eles trabalham em harmonia, enviando informações sobre atividades de tráfegos suspeitos ao processador IDS central, que as coleta e integra e envia alarmes aos administradores da rede quando apropriado

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão



Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Neste cenário a organização dividiu sua rede em duas regiões
    - Uma de segurança máxima
      - Protegida por um filtro de pacotes e um gateway de aplicação e monitorada por sensores IDS
    - Uma região de segurança baixa
      - Zona desmilitarizada (DMZ, do inglês demilitarized zone)
      - Protegida apenas por um filtro de pacotes
      - Também monitorada por sensores IDS
      - Ela inclui os servidores da organização que precisam se comunicar com o mundo externo

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Um IDS precisa
    - Fazer a inspeção profunda do pacote
    - Comparar cada pacote que passa com milhares de assinaturas
  - Por isso não é viável colocar um sensor IDS logo após o filtro de pacotes
    - Ou mesmo integrá-lo ao filtro de pacotes
  - Se uma organização receber tráfego da Internet da ordem de gigabits/s
    - Motivando a utilização de mais de um sensor IDS

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas de detecção de invasão
  - Ao colocar mais sensores IDS, cada sensor só vê uma fração do tráfego da organização
    - Podendo facilmente acompanhar o ritmo
  - Mas hoje existem sistemas IDS e IPS de alto desempenho
    - Muitas organizações podem fazer o acompanhamento com apenas um sensor localizado próximo ao roteador de acesso

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Classificação dos sistemas ID
  - Sistemas baseados em assinatura
  - Sistemas baseados em anomalia
- Assinatura
  - É conjunto de regras relacionadas a uma atividade de invasão
  - Uma assinatura pode ser uma lista de características sobre um único pacote
    - Números de portas de origem e destino
    - Tipo de protocolo
    - Uma sequência de bits em uma carga útil de um pacote

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Assinatura
  - Uma assinatura pode ainda estar relacionada a uma série de pacotes
  - As assinaturas são normalmente criadas por engenheiros experientes em segurança de rede que tenham pesquisado ataques conhecidos
  - O administrador de rede pode personalizar as assinaturas ou inserir suas próprias no banco de dados

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas baseados em assinatura
  - Um IDS baseado em assinatura analisa cada pacote que passa, comparando cada um com as assinaturas no banco de dados
  - Se um pacote (ou uma série deles) corresponder a uma assinatura no banco de dados, o IDS gera um alerta que pode ser
    - Enviado ao administrador da rede por uma mensagem de correio eletrônico
    - Enviado ao sistema de gerenciamento da rede
    - Simplesmente ser registrado para futuras inspeções

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas baseados em assinatura
  - Limitações
    - Requerem conhecimento prévio do ataque para gerar uma assinatura precisa
      - Um IDS baseado em assinatura é completamente cego a novos ataques que ainda não foram registrados
    - Na maioria dos casos, o padrão é comparado apenas se o pacote suspeito estiver associado a um determinado serviço ou, mais precisamente, destinado a uma determinada porta
    - Isso ajuda a diminuir a quantidade de inspeção feita em cada pacote
    - Mas torna mais difícil para o sistema lidar com protocolos que não residem em portas bem definidas

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas baseados em assinatura
  - Limitações
    - Falta de padronização da linguagem de assinaturas
    - Problema na atualização e distribuição de assinaturas
    - Grandes índices de falsos positivos e falsos negativos
    - Redes mais rápidas impedem a análise em tempo real efetivo de todo o tráfego em grandes larguras de bandas

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas baseados em anomalia
  - Um IDS baseado em anomalias cria um perfil de tráfego enquanto observa o tráfego em operação normal.
  - Ele procura por fluxos de pacotes que são estatisticamente incomuns
    - Por exemplo, uma porcentagem irregular de pacotes ICMP ou um crescimento exponencial de análises de porta e varreduras de ping
  - O mais interessante sobre sistemas de IDS baseados em anomalias é que eles não recorrem a conhecimentos prévios de outros ataques
    - Eles conseguem detectar novos ataques que não foram documentados

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Sistemas baseados em anomalia
  - Mas muito desafiador distinguir o tráfego normal de tráfegos estatisticamente incomuns
  - A maioria das implementações de IDS são principalmente baseadas em assinaturas
    - Apesar de algumas terem alguns recursos baseados em anomalias

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Snort
  - É um IDS de código aberto e de domínio público
  - Pode ser executado em plataformas Linux, UNIX e Windows
  - Usa uma interface libpcap de análise genérica
    - A libpcap permite que os usuários se comuniquem com o recurso de captura de pacote fornecido pelo sistema operacional para ler o tráfego de rede não processado
  - Pode facilmente lidar com 100 Mbits/s de tráfego
    - Para velocidades de tráfego de gigabit/s são necessários múltiplos sensores Snort

Segurança Operacional: Firewalls e Sistemas de Detecção de Intrusão

- Snort
  - Há uma vasta comunidade de usuários e especialistas em segurança que mantêm sua base de dados de assinaturas
  - Normalmente, em algumas horas do novo ataque, a comunidade escreve e lança uma assinatura de ataque
  - Essa assinatura é transferida pelas centenas de milhares de execuções de Snort ao redor do mundo
  - Ao usarem a sintaxe da assinatura do Snort, os administradores de rede podem criar suas próprias assinaturas
    - Satisfazendo as necessidades da organização, modificando assinaturas existentes ou criando novas